

AUDIT

ISO 27001 Audit Report May 10th 2026

Northgate University

Prepared By: Kelvin Guzman

ISMS Tabletop Audit Report



TABLE OF CONTENTS

Executive Summary	3
Audit Scope & Methodology	4
ISMS Control Effectiveness & Risk Analysis	6
Detailed Findings & Recommendations	8
4.1 High Risk Findings	8
4.2 Medium Risk Findings	10
4.3 Observations	11
ISO27001:2022 Transition Gap Analysis	12
Conclusion & Final Recommendations	14

Executive Summary

State of the ISMS

Northgate University has built a structurally sound ISMS. Governance documentation is comprehensive, control intent is well-expressed, and the risk management framework is correctly aligned to ISO 27001 principles. That foundation is not the problem. The problem is that the ISMS **operates as a paper system**. Controls are defined but not consistently enforced. Roles are assigned but not consistently validated. Risks are identified but not consistently tracked. In its current state, the ISMS **would not pass a Stage 2 ISO 27001:2022 certification audit**. The gap between policy design and operational evidence would result in multiple nonconformities against Clauses 6.1, 8.2, 9.1, and Annex A controls A.8.1 and A.9.4.

Three Decisions the CISO Must Make in the Next 90 Days

Decision 1 — Mandate MFA and centralized remote access enforcement immediately. This is not a medium-term improvement — it is an active high-risk exposure. Every day the University operates distributed remote access without centralized enforcement and MFA, it accepts residual risk that its own Remote Working Policy does not permit. The CISO must commission a technical implementation within 30 days, not a policy review. Owner: Head of IT Operations. Success criterion: 100% of remote access sessions authenticated via MFA, endpoint compliance checks active, access logs feeding into SIEM within 60 days.

Decision 2 — Activate the risk register as a live governance instrument. The University's risk management methodology is credible on paper. It is not credible in evidence. The CISO must designate a Risk Register Owner, establish a quarterly review cycle with documented outputs, and require all IAOs to submit risk assessments against their asset portfolios within 60 days. The risk register must feed the governance board agenda, not sit as a standalone document. Owner: Information Security Risk Manager. Success criterion: active risk register with dated entries, reviewed at next governance board cycle.

Decision 3 — Commission the ISO 27001:2022 transition gap assessment now. The transition deadline for organizations certified under ISO 27001:2013 passed in October 2025. Any certification body auditing Northgate after that date will assess against the 2022 standard. The University's ISMS has not been formally evaluated against the 11 new controls introduced in the 2022 revision. A structured gap assessment is no longer optional — it is a certification prerequisite. Owner: Lead Information Security Auditor / CISO. Success criterion: formal SoA updated to 2022 Annex A, gap remediation plan in place within 90 days.



Audit Scope & Methodology

Audit Objective

The objective of this audit was to assess the design and implementation of Northgate University's Information Security Management System (ISMS) and determine its alignment with the requirements of **ISO/IEC 27001:2013**. The audit focused on evaluating whether information security controls are appropriately defined, implemented, and capable of effectively managing risks to the confidentiality, integrity, and availability of information assets.

Audit Scope

The scope of the audit included a review of Northgate University's ISMS governance framework, supporting policies, and control environment across key information security domains. The assessment was conducted based on documentation provided by the University, including but not limited to:

- Information Security Policy
- Information Security Risk Management Policy
- Risk Management Methodology
- Information Asset Owners Handbook
- Access Control Policy
- Remote Working Policy
- Cryptographic Policy
- Information Classification Policy
- Acceptable Use Policy

These documents collectively define the University's approach to information security governance, risk management, asset ownership, remote access, cryptographic controls, and acceptable use of information systems.

The audit focused on control domains aligned with ISO 27001 Annex A, including:

- Information security policies (A.5)
- Organization of information security (A.6)
- Asset management (A.8)
- Access control and user responsibilities (A.9)
- Cryptography (A.10)
- Operations and communications security (A.12–A.13)
- Incident management (A.16)

Audit Criteria

The audit was conducted against ISO/IEC 27001:2013, which forms the basis of Northgate University's current certified ISMS. However, given that the transition deadline to ISO/IEC 27001:2022 passed in October 2025, this report also evaluates the University's readiness against the 2022 standard and identifies gaps requiring remediation before the next certification cycle.

Audit Methodology

A **risk-based audit approach** was applied to evaluate the effectiveness of the ISMS. The methodology included:

- **Document Review:**
Detailed analysis of ISMS policies, procedures, and governance documentation to assess alignment with ISO 27001 requirements.
- **Control Mapping:**
Mapping of documented controls to relevant ISO 27001 Annex A control domains to evaluate completeness and coverage.
- **Control Design Assessment:**
Evaluation of whether defined controls adequately address identified risks, including those related to remote access, asset ownership, and data protection.
- **Risk Framework Evaluation:**
Assessment of the University's risk management methodology, including its use of risk registers, CIA-based risk analysis, and alignment with ISO 27005 principles.
- **Consistency and Integration Review:**
Evaluation of how policies, roles (e.g., Information Asset Owners), and risk processes integrate across the ISMS to support consistent implementation and reporting.

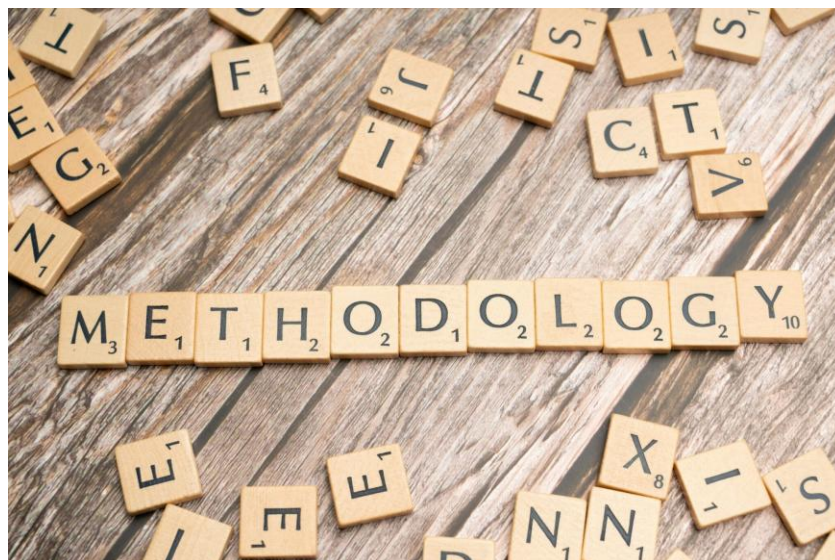
The audit placed emphasis on identifying gaps between **documented controls and their practical application**, particularly in areas requiring ongoing monitoring, accountability, and enforcement.

Audit Limitations

This assessment was conducted based on documentation provided and did not include:

- Direct technical validation of system configurations or controls
- Independent testing of control effectiveness (e.g., penetration testing or system access reviews)
- Interviews with key stakeholders or control owners

As a result, conclusions regarding control effectiveness are based on **design and documented intent**, rather than fully validated operational performance. Areas lacking supporting evidence were treated as potential control gaps requiring further verification.



ISMS Control Effectiveness & Risk Analysis

Control Effectiveness Overview

The assessment indicates that Northgate University has established a **comprehensive and well-structured ISMS framework at the policy and governance level**. Core information security domains—including risk management, asset ownership, remote access, cryptographic controls, and acceptable use—are formally defined and aligned with ISO/IEC 27001:2013 requirements.

Governance controls demonstrate a **high level of maturity in design**, with clearly defined roles, responsibilities, and oversight mechanisms. The University has implemented a structured approach to information security management, supported by executive accountability and formalized policy documentation.

However, at the **operational level**, control effectiveness is assessed as **moderate**, with indications that while policies and procedures are well-defined, **consistent enforcement and evidence of execution are not uniformly demonstrated across all domains**. Key processes—such as asset ownership responsibilities, risk management execution, and remote access control enforcement—rely heavily on documented expectations without sufficient supporting evidence of ongoing validation.

Technical controls, including cryptographic protections and remote access safeguards, are defined in alignment with best practices; however, the audit identified **limited assurance mechanisms to confirm their consistent application across the environment**, particularly in distributed and remote working scenarios.

Risk Posture Summary

Based on the assessment, Northgate University's overall information security risk posture is assessed as **Moderate**.

The University has adopted a **risk-based approach to information security**, supported by a formal risk management policy and methodology aligned with ISO standards. This provides a strong foundation for identifying and managing risks to information assets.

However, several factors contribute to elevated residual risk:

- **Inconsistent operationalization of risk management practices**, including unclear evidence of risk register usage and integration into decision-making processes
- **Reliance on decentralized asset ownership (IAOs)** without consistent validation of accountability or reporting effectiveness
- **Increased exposure from remote working environments**, where unauthorized access, data leakage, and endpoint security risks are more difficult to centrally enforce

These factors increase the likelihood of risks impacting the **confidentiality and integrity of sensitive information**, including personal data, as well as the University's ability to consistently demonstrate compliance with regulatory and contractual obligations.

Control Maturity Snapshot

The maturity of key ISMS domains is summarized as follows:

- **Governance & Policy Framework — High**
The University has established a well-defined ISMS governance structure supported by comprehensive policies and executive oversight.
- **Risk Management — Moderate**
A formal risk management framework and methodology are in place; however, consistent execution, tracking, and reporting of risks require further maturity.
- **Asset Management & Ownership — Low to Moderate**
Asset ownership roles are clearly defined, but evidence of consistent asset-level accountability, classification, and risk ownership is limited.
- **Access Control & Remote Working — Moderate**
Policies governing remote access and acceptable use are established; however, enforcement and monitoring mechanisms require strengthening to reduce exposure.
- **Cryptographic Controls — Moderate to High**
Cryptographic standards and key management practices are defined in accordance with industry best practices, though validation of consistent implementation is limited.
- **User Awareness & Acceptable Use — Moderate**
User responsibilities and acceptable use requirements are clearly documented; however, ongoing compliance and behavioral enforcement depend on effective monitoring and awareness practices.

Key Control Weaknesses

The audit identified several **systemic control weaknesses** that impact the overall effectiveness of the ISMS:

- **Gap Between Policy Definition and Execution**
While policies are comprehensive and aligned with ISO standards, there is limited evidence demonstrating consistent implementation, monitoring, and validation of controls across the organization.
- **Limited Evidence of Control Effectiveness**
Control performance is not consistently supported by measurable evidence (e.g., logs, reporting metrics, or validation processes), reducing assurance that controls operate as intended.
- **Decentralized Accountability Without Strong Oversight**
The reliance on Information Asset Owners introduces potential inconsistencies in how risks are managed and reported, particularly in the absence of centralized validation mechanisms.
- **Risk Management Not Fully Embedded Operationally**
Although a formal risk management methodology exists, its integration into day-to-day operational processes and decision-making appears limited.
- **Remote Working Security as a Primary Exposure Area**
The expanded use of remote access increases the University's attack surface, and current controls may not fully mitigate risks related to endpoint security, user behavior, and unauthorized access.

Detailed Findings & Recommendations

High Risk Findings

1. Inconsistent Enforcement of Remote Access Security Controls

Control Area: A.6.2.2 / A.13 – Remote Working & Network Security

Reference: Remote Working Policy

Finding:

Northgate University has established a comprehensive remote working policy outlining requirements for secure remote access, including the use of VPNs, secure configurations, and user responsibilities. However, the audit identified limited evidence of consistent enforcement and monitoring of these controls across all users and devices.

The policy defines expected behaviors and controls, but does not clearly demonstrate:

- Centralized enforcement mechanisms
- Continuous monitoring of remote access activity
- Validation of endpoint compliance

Risk:

Failure to enforce remote access controls increases the likelihood of:

- Unauthorized system access
- Data leakage from unmanaged or insecure endpoints
- Compromise of sensitive or confidential information

Given the University's reliance on distributed access, this represents significant exposure to confidentiality and integrity risks, particularly for personal and research data.

Recommendation:

- Implement centralized remote access enforcement mechanisms, including mandatory VPN usage and device compliance checks. Recommended tooling: Microsoft Intune (endpoint compliance) or equivalent MDM platform; Beyond Trust or Zscaler for privileged remote access.
- Enforce Multi-Factor Authentication (MFA) across all remote access channels via Azure AD Conditional Access or equivalent identity provider.
- Integrate real-time monitoring and alerting for remote access activity, with logs feeding into a SIEM platform (e.g. Microsoft Sentinel or Splunk).
- Establish periodic validation of endpoint security posture on a minimum quarterly cycle.

Owner: Head of IT Operations Target date: 30 days (MFA mandate); 60 days (centralized enforcement and SIEM integration) Success criterion: 100% of remote access sessions authenticated via MFA; endpoint compliance checks active; access logs captured and reviewed monthly; evidence retained for audit.

2. Weak Operationalization of Asset Ownership Responsibilities

Control Area: A.8.1 – Asset Management

Reference: Information Asset Owners Handbook

Finding:

The University has formally defined the role of Information Asset Owners (IAOs), including responsibilities for managing and protecting information assets. However, the audit identified **insufficient evidence to confirm that these responsibilities are consistently executed in practice.**

Specifically:

- Limited evidence of active asset-level risk assessments
- Unclear consistency in maintaining asset registers
- Lack of standardized reporting from IAOs to governance bodies

Risk:

Without effective asset ownership:

- Critical assets may lack proper classification or protection
- Risks may go unidentified or unmanaged
- Accountability gaps may delay response to security incidents

This creates systemic **risk across multiple ISMS domains**, including access control, data protection, and risk management.

Recommendation:

- Establish formal accountability validation mechanisms for IAOs, including a standardized reporting template submitted to the governance board on a quarterly cycle.
- Require periodic asset-level risk assessments from all IAOs — minimum annual, with a mid-year exception reporting cycle.
- Implement centralized asset inventory tracking with audit oversight, using an existing GRC platform or structured register (e.g. SharePoint-based register with version control as an interim measure).
- Define measurable KPIs for asset ownership performance, including: percentage of assets with a current risk assessment on file; percentage of IAOs with completed annual training; number of overdue asset reviews.

Owner: Information Security Manager / CISO **Target date:** 60 days (reporting template and KPI framework); 90 days (first governance board submission) **Success criterion:** 100% of in-scope assets assigned an active IAO with a dated risk assessment on file; quarterly IAO report presented at governance board; KPIs baselined and reported.

Medium Risk Findings

3. Risk Management Framework Not Fully Embedded in Operations

Control Area: Clause 6 / A.8 – Risk Management

Reference: Risk Management Policy & Methodology

Finding:

Northgate University has a well-defined risk management framework aligned with ISO standards. However, the audit identified that this framework is not being actively executed as an operational process.

Specifically, there is no evidence that risk assessments are being performed on a scheduled basis, that the risk register is being updated with new or changed risks, or that risk treatment decisions are being documented and tracked through to completion. The framework exists as a designed process but is not functioning as a live governance instrument.

Key gaps include:

- Unclear usage of a centralized risk register
- Limited visibility into how risks are tracked and updated
- Lack of integration between risk assessments and control validation

Risk:

- Inconsistent identification and treatment of risks
- Misalignment between risk exposure and control implementation
- Reduced ability to prioritize security investments effectively

Recommendation:

- Designate a named Risk Register Owner accountable for maintaining and updating the centralized risk register on a defined cycle.
- Enforce the use of the centralized risk register across all business units, with a minimum quarterly update requirement and escalation process for risks rated High or Critical.
- Integrate risk register outputs into governance and reporting cycles — the risk register must appear as a standing agenda item at the Information Security governance board.
- Establish regular risk review processes tied to IAO reporting and control performance monitoring, with a defined review cadence (quarterly minimum).

Owner: Information Security Risk Manager **Target date:** 30 days (Risk Register Owner designated and register reviewed); 60 days (first governance board submission with risk register output)

Success criterion: Active risk register with dated entries; all High-rated risks assigned an owner and treatment plan; risk register reviewed at governance board with documented minutes.

4. Limited Evidence of Control Performance Monitoring

Control Area: A.12 / A.16 – Monitoring & Incident Management

Finding:

Separate from the risk management process, the audit identified that there is no ongoing visibility into whether implemented controls are performing as intended on a day-to-day basis. There is no evidence of audit log reviews, no defined Key Risk Indicators or Key Control Indicators, and no monitoring dashboard or reporting mechanism that would alert the organization to a control failure between formal audit cycles. This means controls could degrade or fail entirely without detection.

Lack of documented metrics for control performance

- Limited visibility into audit logs, monitoring outputs, or review processes
- Insufficient demonstration of continuous control validation

Risk:

- Controls may exist but fail without detection
- Increased time to identify and respond to incidents
- Reduced assurance of ISMS effectiveness



Recommendation:

- Define a minimum KRI and KCI framework covering the four highest-risk control domains identified in this audit: remote access, asset management, risk management, and incident response. Each indicator must have a defined threshold, owner, and review frequency.
- Implement centralized logging and monitoring, with access logs, system events, and policy exception reports feeding into a central dashboard reviewed on a monthly cycle.
- Establish a formal control performance review cycle — minimum quarterly — with documented outputs presented to the CISO and governance board.
- Retain evidence of all monitoring activities (log exports, review records, exception reports) to support future internal and external audit activities.

Owner: Information Security Manager / IT Operations Lead **Target date:** 45 days (KRI/KCI framework defined); 90 days (first monthly monitoring report produced) **Success criterion:** Documented KRI/KCI framework in place; monthly monitoring reports produced and retained for minimum 12 months; control performance presented at governance board on quarterly cycle.

Observations (Low Risk / Improvement Opportunities)

5. Strong Policy Framework with Opportunity for Enhanced Integration

Control Area: Governance / ISMS Framework

Reference: Information Security Policy

Observation:

Northgate University has developed a **comprehensive and well-aligned policy framework**, covering key ISMS domains and demonstrating strong alignment with ISO 27001 principles.

However, opportunities exist to:

- Improve **integration between policies and operational processes**
- Enhance **cross-domain visibility of control implementation**
- Strengthen **linkages between governance, risk, and technical controls**

Impact:

While not a direct control failure, improved integration would:

- Increase ISMS efficiency
- Strengthen audit readiness
- Enhance overall security posture

Recommendation:

- Align policies with **centralized governance dashboards and reporting structures**
- Improve **traceability between risks, controls, and outcomes**

ISO 27001:2022 Transition Gap Analysis

This audit was conducted against ISO/IEC 27001:2013. The transition deadline to ISO/IEC 27001:2022 passed in October 2025, after which all certification bodies began assessing against the revised standard exclusively. The 2022 revision restructured Annex A from 114 controls across 14 domains to 93 controls across 4 themes (Organizational, People, Physical, Technological), and introduced 11 new controls not present in the 2013 version. The table below identifies each new control, its relevance to Northgate University's ISMS, and a preliminary gap assessment based on documentation reviewed in this audit.

Gap Status key: Gap — High Priority = control not addressed and directly relevant to current risk exposure; Not Assessed = not evaluated in this audit scope, requires inclusion in next assessment; Partially Addressed = some coverage exists but formalization required against 2022 framework; Lower Relevance = may be scoped out of applicability with documented justification in the SoA.

Control	Control Name	Gap Status	Relevance to Northgate University ISMS
5.7	Threat Intelligence	Not Assessed	No threat intelligence function or feed referenced in ISMS documentation. High relevance given the University's research data exposure and external collaboration profile.
5.23	Information Security for Use of Cloud Services	Gap — High Priority	No cloud security policy in scope. Critical gap given the University's likely dependency on cloud platforms (Microsoft 365, research collaboration tools). Must be addressed as part of 2022 transition.
5.30	ICT Readiness for Business Continuity	Gap — High Priority	Business continuity planning for ICT systems not covered in reviewed documentation. Relevant given dependency on distributed remote access.
7.4	Physical Security Monitoring	Not Assessed	Physical security monitoring is a facilities/premises control, outside this documentation-review scope; to be assessed with facilities management.
8.9	Configuration Management	Gap — High Priority	No configuration management or secure-baseline/hardening standard evidenced. High risk given unvalidated remote endpoints; supports R07.
8.10	Information Deletion	Gap — High Priority	Data retention and secure deletion not addressed in reviewed policies; UK GDPR Article 17 (right to erasure) relevance. Supports R08.
8.11	Data Masking	Not Assessed	No data masking or pseudonymisation requirements documented. Relevant to personal data under UK GDPR and sensitive research data handling.
8.12	Data Leakage Prevention	Partially Addressed	Partly addressed via classification and acceptable use; no technical data-leakage-prevention tooling evidenced. Relevant to PII and research data.
8.16	Monitoring Activities	Gap — High Priority	Directly mirrors Finding 4 (limited control performance monitoring). No KRIs, KCIs, or audit log review processes evidenced. Formalizing this under the 2022 framework is a certification prerequisite.
8.23	Web Filtering	Gap — High Priority	Web filtering controls not referenced in the Acceptable Use Policy or Remote Working Policy. Relevant for remote endpoints where institutional network controls cannot be guaranteed.
8.28	Secure Coding	Lower Relevance	Relevant only if the University develops or procures bespoke software. If applicable, a secure development lifecycle must be documented in a future audit scope.

Risk Heat Map — Findings Summary

The matrix below plots each audit finding against its assessed likelihood and impact. Risk levels reflect inherent risk prior to remediation. Residual risk will reduce as recommended controls are implemented and validated.

	Low Likelihood	Medium Likelihood	High Likelihood
High Impact	MEDIUM	HIGH	HIGH — F1, F2
Medium Impact	LOW	MEDIUM	HIGH — F3, F4
Low Impact	LOW — F5	LOW	MEDIUM

F1: Inconsistent Enforcement of Remote Access Security Controls | F2: Weak Operationalization of Asset Ownership Responsibilities | F3: Risk Management Framework Not Fully Embedded in Operations | F4: Limited Evidence of Control Performance Monitoring | F5: Strong Policy Framework — Opportunity for Enhanced Integration (Observation)

Rationale for placement:

- F1 (High/High) Remote access without MFA or endpoint enforcement is an active exposure with high likelihood of exploitation and high potential impact on confidentiality and regulatory standing.
- F2 (High/High) Asset ownership gaps are operationally widespread across IAO roles, making recurrence highly likely. Impact is high given link to data classification and access control decisions.
- F3 (High/Medium) Risk register exists but is not operationalized. Likelihood of this persisting is high; impact is medium as the framework design partially mitigates exposure.
- F4 (High/Medium) No monitoring or log review program evidenced. Likelihood of ongoing control failures going undetected is high; impact is medium as no confirmed incidents have been identified.
- F5 (Low/Low) Positive observation. Strong policy foundation reduces both likelihood of control design failure and impact from governance weaknesses.



Conclusion & Final Recommendations

At a strategic level, the University demonstrates clear commitment to information security, with well-documented controls across key domains including asset management, risk management, remote access, and cryptographic protections. This provides a solid basis for managing risks to the confidentiality, integrity, and availability of information assets.

However, the effectiveness of the ISMS is currently constrained by **inconsistent operational execution and limited evidence of control validation**. The audit identified a recurring pattern across multiple domains: **controls are well-defined but not consistently enforced, measured, or evidenced in practice**. This gap between policy design and real-world implementation represents the primary driver of residual risk.

Key exposure areas—including **remote working security, asset ownership accountability, and the operational integration of risk management processes**—present elevated risks to the organization. If not addressed, these gaps may increase the likelihood of unauthorized access, data compromise, and challenges in demonstrating regulatory compliance, particularly in relation to personal data protection.

Overall ISMS Assessment

- **Design Maturity:** High
- **Operational Effectiveness:** Moderate
- **Overall Risk Posture:** Moderate

The ISMS is **well-positioned for maturity advancement** but requires targeted improvements to transition from a policy-driven framework to a **fully operational, evidence-based control environment**.

Strategic Recommendations

To strengthen the effectiveness of the ISMS and support alignment with ISO 27001 certification expectations, the following priority actions are recommended:

1. Strengthen Control Enforcement and Validation

- Implement mechanisms to ensure that all defined controls—particularly those related to remote access and user behavior—are **consistently enforced and centrally monitored**
- Introduce regular validation processes to confirm control effectiveness across all business units

2. Establish Evidence-Based Monitoring and Reporting

- Define and implement **Key Risk Indicators (KRIs)** and **Key Control Indicators (KCIs)**
- Develop centralized reporting dashboards to provide **continuous visibility into control performance, risk status, and compliance posture**
- Ensure that all critical controls are supported by **auditable evidence** (e.g., logs, reports, review records)

3. Enhance Asset Ownership Accountability

- Formalize and enforce **performance expectations for Information Asset Owners (IAOs)**
- Require periodic reporting on asset-level risks, classifications, and control status

- Implement centralized oversight to validate that asset ownership responsibilities are consistently executed

4. Embed Risk Management into Operational Processes

- Ensure that the defined risk management methodology is **actively used across all departments**
- Maintain a **centralized and regularly updated risk register**
- Integrate risk assessment outputs into **decision-making, control implementation, and governance reporting**

5. Reduce Exposure from Remote Working Environments

- Strengthen controls governing remote access, including:
 - Mandatory MFA enforcement
 - Endpoint security validation
 - Real-time monitoring of access activity
- Regularly review remote access risks in alignment with evolving threat landscapes